Vapt_task

Author: Dheeraj
Project: Security Assessment & VAPT Practical
Date: Thursday, 26-02-2026

Security Assessment & VAPT Practical Report

---

1. Introduction

This report documents the theoretical understanding and practical implementation of a security assessment conducted in a controlled lab environment.

The objective was to evaluate a vulnerable system using open-source tools and follow a structured VAPT methodology without relying on commercial security platforms.

Testing was performed in an isolated VirtualBox lab using Kali Linux and Metasploitable 3.

---

2. Understanding Security Assessment

A security assessment is the process of identifying weaknesses in systems, networks, or applications before they can be exploited by attackers.

Types of Security Testing

1. Vulnerability Assessment
Focuses on identifying and listing vulnerabilities.
Tool used: OpenVAS

2. Penetration Testing
Simulates real-world attacks to validate vulnerabilities.
Tool used: Metasploit Framework

3. Compliance Testing
Validates security posture against standards such as:

- ISO 27001
- GDPR
- HIPAA
- CIS Benchmarks

3. VAPT Methodology

The assessment followed a structured lifecycle approach.

3.1 Planning Phase

- Defined scope: Metasploitable 3 VM
- Identified target IP address
- Testing conducted in isolated lab
- Tools selected before execution

3.2 Discovery Phase

Network Scanning (Nmap)

Command used:

```
nmap -sC -sV -p- -oN scan.txt 127.0.0.1
```

```
Nmap scan report for 192.168.19.12
Host is up (0.0028s latency).
Not shown: 987 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
1801/tcp open  msmq
2103/tcp open  zephyr-clt
2105/tcp open  eklogin
2107/tcp open  msmq-mgmt
3389/tcp open  ms-wbt-server
5357/tcp open  wsdapi
8000/tcp open  http-alt
8089/tcp open  unknown
MAC Address: 00:0C:29:D5:10:B1 (VMware)

Host script results:
|_ipidseq: Incremental!

Nmap done: 1 IP address (1 host up) scanned in 2.14 seconds
```

Purpose:

- Identify open ports
- Detect running services
- Identify service versions

Observation:
Multiple ports were open including FTP, SSH, HTTP, and SMB.

Web Server Scanning (Nikto)

Command used:

```
nikto -h http://<target-ip>
```

```
┌──(kali㉿222vm)-[~]
└─$ nikto --host 192.168.40.168
- Nikto v2.1.6
---------------------------------------------------------------------------
+ Target IP:          192.168.40.168
+ Target Hostname:    192.168.40.168
+ Target Port:        80
+ Start Time:         2023-09-14 22:44:28 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hin
t to the user agent to protect against some forms of XSS
```

Purpose:

- Identify outdated server software
- Detect misconfigurations
- Discover common vulnerabilities

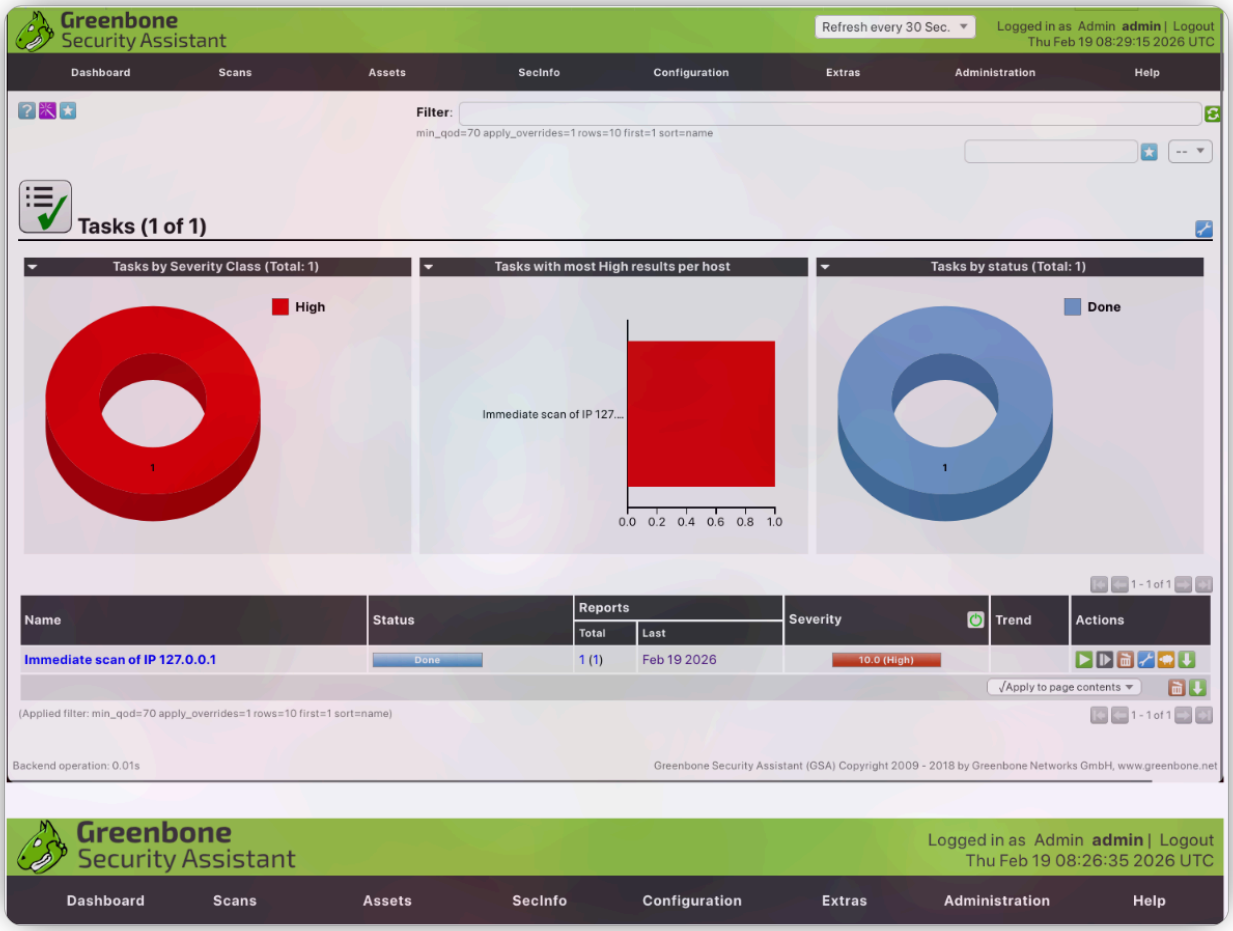
Vulnerability Scanning (OpenVAS)

OpenVAS was used to perform automated vulnerability scanning.

Results included:

- Outdated services

- Weak configurations
- Known CVEs with CVSS scores



3.3 Attack Phase

Metasploit Framework was used to validate selected vulnerabilities.

Example process:

- Selected relevant exploit module
- Configured RHOST and payload
- Executed exploit in controlled environment

Exploitation was performed only to validate risk severity.

3.4 Reporting Phase

All findings were documented with:

- Target IP
- Port number
- Service name
- CVE (if available)
- CVSS score
- Screenshot evidence
- Remediation recommendation

---

4. Risk Assessment

CVSS Scoring

The CVSS scoring system was used to evaluate severity levels.

Severity Categories:

- 0.1–3.9 → Low
- 4.0–6.9 → Medium
- 7.0–8.9 → High
- 9.0–10 → Critical

Risk Matrix

A 3x3 risk matrix was used based on:

- Likelihood (Low / Medium / High)
- Impact (Low / Medium / High)

This helped prioritize remediation efforts.

---

5. Common Vulnerabilities Identified

Network-Level Issues

- Open ports exposing unnecessary services
- Outdated service versions
- Anonymous FTP access (if applicable)

Web Application Issues

- Potential SQL Injection
- Cross-Site Scripting (XSS)
- Directory listing enabled

Testing practice platforms:

- OWASP Juice Shop
- Metasploitable 3

---

6. Documentation Approach

Findings were tracked using:

- Obsidian for structured documentation
- Screenshots for proof of concept
- Spreadsheet for vulnerability tracking
- Manual notes for methodology tracking

---

7. Executive Summary

The assessment identified multiple vulnerabilities including outdated services and misconfigurations. Some vulnerabilities were categorized as High severity based on CVSS

scoring.

Immediate remediation is recommended including:

- Updating vulnerable software
- Disabling unused services
- Applying security patches
- Implementing firewall restrictions

The lab exercise demonstrated the importance of structured testing methodology and proper documentation during security assessments.

---

8. Conclusion

This practical exercise improved understanding of:

- Structured VAPT methodology
- Vulnerability scanning techniques
- Risk prioritization
- Technical documentation standards

The assessment was performed ethically within a controlled lab environment.